

TRIAGE-LINK — Filling the Gaps: Delivery Plan (Class-A foundations)

Purpose. The actionable "how" for the prototype→product gaps that are **buildable now, offline-first, and path-independent** (Class A in `productization-gap-backlog.md`). Each item gives the technical approach grounded in the current code, architecture fit, schema/code touchpoints, sequencing, effort, acceptance criteria, and test plan. Class-B (backend/path-gated) gaps are listed at the end with the decision each needs first.

Why Class A first: these foundations are needed by *every* commercial path, extend what's already shipped (the vault + op-log), and a future SaMD/EMS submission reuses them — so the work is never wasted regardless of beachhead.

Prepared 2026-06-27.

Guardrails (apply to every item — from `CLAUDE.md`)

1. **Offline-first / no-backend stays the default.** Nothing here introduces a server. Every feature works on a disconnected device.
2. **Default-off for risky features.** New capabilities ship gated so the community build and the existing test suite behave identically until switched on.
3. **i18n is four languages, always in sync.** Any UI string → EN/FR/AR/FA (parity test enforces it).
4. **Tutorial parity.** Any user-visible change updates the guided tour + `tour.*` strings in all languages.
5. **Verify before done.** `typecheck` + `test:report` + `build` + Playwright e2e green before claiming complete. One PR per item, CI-gated.

Current foundations to build on

- **Encryption:** `src/db/vault.ts`, `record-crypto.ts`, `crypto.ts` — AES-256-GCM, opt-in vault, seal/open at the repository boundary.
- **Journaling spine:** `src/db/oplog.ts` + the `ops` table already record every record mutation as immutable, Lamport-ordered ops (carrying a device `clientId`, but **no operator identity**).
- **Schema:** Dexie at **v3** (`records`, `ops`, `meta`, `photos`); new tables land at **v4**.
- **i18n:** `Lang` is a fixed union `'en'|'fr'|'ar'|'fa'`; `LANGS`, `RTL_LANGS`, `DICTS` are compiled in.

Item 1 — Always-on encryption policy (*effort: M*)

Gap. The vault is opt-in/default-off; commercial/PHI use needs encryption that an org can **enforce**.

Approach. Introduce a **vault policy** with two sources: a build-time flag (`VITE_VAULT_REQUIRED`) for distribution builds, and a persisted org setting in `meta`. When *required*:

- First run shows a **"set a passphrase"** screen (reuse `VaultLock` styling) before any record can be saved.
- The menu's **"Turn off encryption"** action is hidden; `disableVault()` refuses unless policy allows.
- Optionally tighten the auto-lock default.

Architecture fit. Extend `vault.ts` with `getPolicy()/isRequired()` reading `import.meta.env.VITE_VAULT_REQUIRED` U a `vault.policy` meta row. `App.tsx` gates first-save on an unlocked vault when required. **Default (unset) = today's behavior exactly.**

Touchpoints. `src/db/vault.ts`, `src/App.tsx`, `src/components/VaultLock.tsx`, `src/i18n.tsx` (set-passphrase strings ×4), `Tutorial.tsx` (mention if visible).

Acceptance. With policy on: no plaintext record can be written; first-run forces a passphrase; disable is hidden. With policy off (default): byte-for-byte current behavior; full suite green.

Tests. Unit (policy gating, disable refusal); e2e (forced first-run setup → save works only after passphrase set).

Item 2 — On-device immutable audit log (*effort: L*)

Gap. The op-log records *record mutations* but not **access/security events** (view, export, backup, vault lock/unlock, operator sign-in), and there's no tamper-evidence or admin view. Audit trails are a procurement gate (PHIPA/HIPAA-grade) for every path.

Approach. New **append-only audit table** (Dexie **v4**). Each entry: `{ id, ts, actor, action, recordId?, detail }` where `action ∈ {record.create|view|update|delete|export, backup.create|restore, vault.unlock|lock, operator.login}`. **No update/delete API** — append only. **Hash-chain** each entry (`hash = SHA-256(prevHash + canonical(entry))`), using `crypto.ts` for **tamper-evidence without a server**. When the vault is on, audit entries are **sealed** like records/ops (extend `record-crypto.ts`). Ship a read-only **Audit viewer** (admin) with **export** + a **chain-verify** action.

Architecture fit. A small `audit(action, ctx)` helper called from `repository.ts` (create/view/update/remove/export paths), `backup.ts`, and `vault.ts`. Actor is the active operator (Item 3) or the device `clientId` until then. Hash-chain head stored in `meta`.

Touchpoints. `src/db/database.ts` (v4 + `audit` table), new `src/db/audit.ts`, `src/db/repository.ts` / `backup.ts` / `vault.ts` (emit events), `src/db/record-crypto.ts` (seal audit), new `src/components/AuditLog.tsx`, `i18n.tsx` (×4), `Tutorial.tsx`.

Acceptance. Every PHI access/mutation/export/backup/lock emits an entry; there is no API to mutate/delete entries; the chain verifies and **a tampered entry is detected**; entries are encrypted at rest when the vault is on; viewer lists + exports them; with the feature absent the rest of the app is unchanged.

Tests. Unit (append-only invariant, hash-chain integrity, tamper detection, seal/open round-trip); integration (save/get/export emit the right events); e2e (perform actions → audit viewer shows them → verify passes).

Item 3 — Operator profiles + record attribution (RBAC-lite) (*effort: M-L*)

Gap. Single-user; no identity. A shared field tablet can't attribute records to the medic, and there are no roles to gate admin views (audit, operator management). Records/ops carry no operator.

Approach. Local **operator roster** (no backend): an `operators` table (v4) of `{ id, name, role }`, `role ∈ {field, lead, admin}`, with an **active operator** selector and an **optional PIN** per operator (a soft gate, not full auth). Stamp `record.author`, each op, and each audit entry with the active operator. **RBAC-lite:** `admin` / `lead` gate the Audit viewer and operator management. Default single-operator experience stays one tap.

Architecture fit. `src/db/operators.ts` (CRUD + active-operator in `meta` /memory); `repository.save` sets `author`; `oplog` / `audit` read the active operator for actor; a small operator switcher in the header; role checks gate admin UI. `CasualtyRecord` gains an optional `author` (core type) — additive, non-breaking.

Touchpoints. `packages/core/src/domain/types.ts` (optional `author`), `src/db/database.ts` (v4 + `operators`), new `src/db/operators.ts`, `src/db/repository.ts`, `src/components/` (operator switcher + admin), `i18n.tsx` (×4), `Tutorial.tsx`.

Acceptance. Add/switch operators; new records + audit entries attributed to the active operator; roles gate admin views; fully offline; with a single operator the UX stays minimal.

Tests. Unit (attribution, role gating); e2e (add operator → switch → record shows author; non-admin can't open admin views).

Item 4 — Import / export / migration (*effort: M*)

Gap. `backup.ts` does whole-DB export/import (plain + encrypted) and per-record **FHIR** export exists, but there's no **roster/CSV** export for analytics/QA and no **migration-in**

path from paper/CSV/other tools — anti-lock-in is a real buying signal in this sector (cf. the Prehos collapse).

Approach. Add **CSV export** (roster + flattened records) and a documented **data schema**; add **CSV import** with a simple field-mapping step; reuse the existing **FHIR bundle export** for interoperable single-record portability. All client-side.

Touchpoints. New `src/db/csv.ts` (encode/decode), `src/App.tsx` (export/import actions), `i18n.tsx` (×4), `Tutorial.tsx`, a short schema doc.

Acceptance. Export a roster CSV; re-import it to reconstruct records (round-trip); documented schema; FHIR per-record export unchanged.

Tests. Unit (CSV round-trip, malformed input); e2e (export → file downloaded; import → records appear).

Item 5 — Accessibility (WCAG) pass (*effort: M-L*)

Gap. No formal ally conformance; field use (gloves, sunlight, stress) and procurement both demand it.

Approach. Audit + fix: keyboard operability and **focus management** for every overlay (`Tutorial`, `PhotoLightbox`, `CasualtySummary`, `SceneSummary`, `TriageBoard`, `VaultLock`), ARIA roles/labels, **colour-contrast** (triage colours on their backgrounds), **tap-target** sizes, reduced-motion, and screen-reader labelling of the body chart/markers. Wire **axe-core** into the Playwright suite as an automated gate on key screens.

Touchpoints. Component-wide (focus traps, ARIA), `styles.css` (contrast/targets), `e2e/` (axe-core spec), `package.json` (`@axe-core/playwright` dev dep).

Acceptance. axe-core reports no serious/critical violations on the capture screen, board, summary, and vault; all overlays are keyboard-operable with a focus trap + Escape; documented conformance statement.

Tests. axe-core integration spec; keyboard-navigation e2e for overlays.

Item 6 — Language extensibility (runtime language packs) (*effort: M*)

Gap. Adding a language = code change + release (`Lang` is a compiled union). NGOs need to add e.g. Ukrainian/Pashto/Swahili **without** a release — a direct selling point.

Approach. Allow a **runtime language pack** (JSON of the flat `Dict` shape + an `rtl` flag + a BCP-47 code) to be **loaded at runtime** (file upload now; URL/config later), merged over the base, with **English fallback** for missing keys. Loosen `Lang` from a closed union to `string` with the four built-ins as defaults; make `LANGS`, `RTL_LANGS`, and the active dictionary **registry-backed**. Built-in dictionaries and the parity test stay as the baseline.

Architecture fit. Refactor `src/i18n.tsx`: `type Lang = string`; a runtime `registerLanguage(code, dict, {rtl})`; `t()` falls back to English per-key; `SPEECH_LANG` falls back by base subtag. The four built-ins register at startup, so default behavior is unchanged.

Touchpoints. `src/i18n.tsx`, `src/components/Tutorial.tsx` (`SPEECH_LANG` fallback), an admin "Load language pack" action, a pack schema doc, `test/i18n.test.ts` (keep built-in parity; add fallback tests).

Acceptance. Load a JSON pack at runtime → the language is selectable, RTL honoured, missing keys fall back to English, voice-over picks the base subtag; the four built-ins and their parity test are unaffected.

Tests. Unit (register + fallback + RTL); e2e (load a pack → switch → strings render, RTL applied).

Item 7 — Onboarding & support assets (*effort: S-M, mostly non-code*)

Gap. The guided tour covers usage, but there's no admin/clinical quick-start, deployment guide for a field team, or support runbook.

Approach. Author concise **admin/clinical quick-start** + **field-deployment** guides (Markdown→PDF via the existing `scripts/` pipeline) and a support/issue runbook. Largely documentation, not code.

Acceptance. Published guides; a documented support process.

Sequencing & PR order

Security/compliance foundation (do in order – each builds on the last):

- PR1 Always-on encryption policy (Item 1, M)
- PR2 Immutable audit log (actor=device) (Item 2, L) ← depends on crypto/seal
- PR3 Operator profiles + attribution (Item 3, M-L) ← enriches audit actor + adds
- PR4 Wire RBAC to gate audit/admin views (small follow-up)

Portability & access (independent – parallelizable, any order):

- PR5 Import/export/migration (CSV) (Item 4, M)
- PR6 Runtime language packs (Item 6, M)
- PR7 Accessibility (WCAG) + axe-core (Item 5, M-L)

Docs (anytime):

- PR8 Onboarding/support guides (Item 7, S-M)

Recommended start: PR1 (always-on encryption policy) — smallest, self-contained, extends the merged vault, and unblocks the audit/operator chain.

Definition of Done (every PR)

- ☐ `npm run typecheck` clean (root + workspaces)
- ☐ `npm run test:report` green (+ new unit/integration tests)
- ☐ `npm run build` clean
- ☐ Playwright e2e green (+ new spec)
- ☐ i18n parity (EN/FR/AR/FA) for any new strings
- ☐ Guided tour updated if user-visible (tutorial parity)
- ☐ Default-off / offline-first preserved; community build behavior unchanged
- ☐ PR opened, CI green, squash-merged, branch synced

Out of scope here — Class-B (path-gated) gaps

These need a **beachhead/architecture decision** first because they imply a backend or regulated-market commitment (see `commercialization-index.md`):

Gap	Blocked on
Multi-tenant org model, SSO	Decision to run a hosted/identity backend
Hosted sync + DR + observability + SLA	Same; productionizing <code>packages/sync-service</code>
SOC 2 Type II	Enterprise/government target + hosted service
OADS v4.0 / NEMSIS conformance	Decision to enter the official-EMS channel (Phase 3)
CAD/dispatch + hospital-EHR integration	EMS channel + partner agreements
Certified SaMD evidence stack	Intended-use = SaMD decision (<code>regulatory-privacy-brief.md</code>)

When you pick a beachhead, the relevant Class-B items become a focused follow-on plan.